EWB COURSES

# AI-POWERED CYBERSECURITY

## Assessment 01: Security Foundations

### Individual Assessment Report

| | |
|---|---|
| **Student name** | Sreelekha Battina |
| **Batch / Group** | Not provided |
| **Assessment** | EWB-Cybersecurity-Assessment-01 |
| **Tasks covered** | A — Account security; B — Phishing analysis; C — Sign-in-log investigation; D — AI-answer review |
| **Basis** | Fictional scenarios and synthetic evidence supplied in the assessment brief |

Prepared as an educational analysis. All accounts, domains, IP addresses and events discussed in Tasks B and C are fictional training evidence. No live systems were tested.

# Task A — Secure a student account

## A1–A2. Risks, assets, CIA impact and controls

Mira's behaviour creates several distinct risks. The table links each risk to the asset affected, the relevant confidentiality, integrity or availability (CIA) impact, and a practical control with its limitation.

| Risk | Asset at risk | CIA impact | Practical control | Limitation |
|---|---|---|---|---|
| Same short password used for email and learning portal | Email and learning-portal accounts | Confidentiality: compromise of one service may expose both accounts. Integrity: an intruder could alter account or course information. | Use a long, unique password for each account; store it in a reputable password manager. | A password manager itself must be protected, and a unique password cannot prevent phishing or malware. |
| Approves unexpected sign-in prompts | Account credentials, sessions and personal/course data | Confidentiality and integrity: an unauthorised person may gain access and view or change information. | Deny unexpected prompts; use number-matching or phishing-resistant MFA where available, and report repeated prompts. | MFA reduces risk but is not a guarantee; users can still approve a deceptive prompt or lose a device. |
| Postpones device updates | Laptop, stored files and accounts accessed from it | Confidentiality, integrity and availability: known vulnerabilities may be exploited to steal, alter, encrypt or disrupt data. | Enable automatic operating-system, browser and application updates and restart promptly. | Updates may occasionally cause compatibility problems and do not replace backups or safe behaviour. |
| Only one project copy is kept on one laptop | Project files and coursework | Availability and integrity: device failure, theft, ransomware or accidental deletion could destroy the only copy. | Maintain versioned backups in a separate, trusted location; periodically test restoring a file. | Cloud or external backups can also be compromised or become unavailable; backups must be kept current and protected. |
| Friend uses laptop while Mira remains signed in | Learning portal, email, private files and active sessions | Confidentiality: friend may see private data. Integrity: files or submissions may be changed. Availability: files may be deleted. | Use a separate standard user account for the friend; lock the screen and sign out of sensitive services. | Separate accounts do not prevent physical damage or misuse if Mira shares her own credentials. |

## Prioritised first three actions

**1. Stop approving unexpected prompts and secure the accounts.** This is first because an attacker may currently be attempting access. Mira should deny unrecognised requests, change the reused password to unique passwords from a trusted device, and review active sessions. Enable an appropriate MFA method.

**2. Create a separate, verified backup of project work.** This quickly reduces the risk of losing the only copy through device failure, ransomware or accidental deletion. Test that at least one file can be restored.

**3. Update the laptop and separate access.** Install pending security updates, restart, create a separate account for the friend, and lock the device when unattended. These measures reduce exposure and prevent casual access.

The first action is most urgent because account access may be actively at risk; the second protects irreplaceable work; the third reduces ongoing device and shared-use risks. The actions can overlap, but account containment should not be delayed.

## A3. Authentication versus authorisation

**Authentication** establishes who is signing in. For example, Mira enters her username and password and completes an MFA check to demonstrate that she is the account holder. **Authorisation** determines what an authenticated user is permitted to do. After Mira signs in, the learning portal may allow her to view her own course materials and submit assignments, while only an instructor may edit grades. Successful authentication does not automatically grant every permission.

# Task B — Analyse a suspicious message

## B1. Five warning signs

The assessment asks for analysis of the supplied text, not proof that a real sender or website is malicious. The .example domains are fictional training addresses and must not be visited.

| Evidence phrase | Why it needs scrutiny |
|---|---|
| "Reply-To: help@personal-awards.example" | The reply address differs from the displayed sender and uses a separate, personal-sounding domain. This mismatch should be verified independently; it is not proof by itself. |
| "FINAL WARNING" and "in 20 minutes" | An urgent deadline pressures the recipient to act before checking the request. Urgency is a common social-engineering technique. |
| "enter your college password and OTP" | A message asking for both a password and one-time passcode is highly risky. Passwords and OTPs should not be disclosed through a message link or reply. |
| "Do not contact the college office" | It discourages independent verification and attempts to isolate the recipient from a trusted channel. |
| "Reply with a photo of your identity card" | It requests sensitive identity information that could be misused. A scholarship process should be confirmed through an official college channel. |

## B2. Safe verification process

1. Do not click the message link, reply, open attachments or provide credentials, OTPs or identity documents. Preserve the message for reporting.

2. Open the college portal using a bookmark or an address already published in official college material. Alternatively, obtain the scholarship office's phone number or email from the college's official website, student handbook or administration—not from this message.

3. Ask the office whether the scholarship, deadline and requested documents are genuine. Report the message through the college's official IT/security or student-support channel.

HTTPS encrypts a connection between a browser and a site; it does not establish that the site belongs to the college or that its request is legitimate. A familiar display name can be chosen or imitated and does not authenticate the sender. The sender address, domain, link destination and request must be checked through an independent channel.

## B3. If a student already entered a password and OTP

1. **Contain immediately:** From a trusted device and by using the independently verified official portal, change the affected password. If it was reused, change it on every other service where it was used. Do not send the password or OTP to anyone.

2. **Revoke access:** Use the account's official security settings to sign out other sessions and review recovery details, registered devices and MFA methods. If the student cannot access the account, contact the college IT team through an official channel and request account recovery or temporary protection.

3. **Report:** Notify the college IT/security team and scholarship office. Provide the original message, sender/reply-to details, time received and actions taken, while keeping credentials and OTPs private.

4. **Follow up:** Check recent sign-in activity, unfamiliar sessions, forwarding rules or account changes, and unexpected messages sent from the account. Continue monitoring and follow IT instructions. If identity-card information was shared, tell the college and follow its identity-document guidance.

## B4. What cannot be established

From the text alone, we cannot establish who actually sent the message or whether the displayed website is controlled by the college, a third party or an attacker. Helpful additional evidence would include full email headers (including authentication results), independently verified domain ownership and confirmation from the college's scholarship office. Even then, evidence should be assessed together rather than relying on one indicator.

# Task C — Triage a sign-in alert

## C1. Four-point timeline: observations and interpretation

| Time (IST, 18 Oct 2026) | Observed evidence | Interpretation (not a proven fact) |
|---|---|---|
| 09:00–09:01 | Password success and MFA approved for student07 from 192.0.2.10, the usual classroom egress IP according to the lab notes. | A successful sign-in occurred from the usual egress. The log does not independently prove who operated the account. |
| 10:14–10:15 | Two password failures for student07 from 198.51.100.23. | There were two unsuccessful attempts from a different source IP. They may reflect mistyped credentials or an unauthorised attempt. |
| 10:16–10:17 | Password success from 198.51.100.23, followed by an MFA denial. | The password was accepted, but the first recorded MFA attempt was denied. This could indicate that someone had a correct password but did not initially complete MFA. |
| 10:18–10:20 | MFA approved at 10:18; session created at 10:20. Student07 says they did not sign in after 09:05 and approved a prompt to stop repeated requests. | The user's statement connects the approval to the prompt sequence. The approval may have enabled the session, but the log alone does not prove who used it or what activity followed. |

## C2. Likely explanation, alternative and checks

**Likely explanation:** An unauthorised person may have obtained or guessed the student's password, made repeated sign-in attempts, and then triggered MFA prompts. Student07's approval at 10:18 may have allowed the sign-in to complete, after which a session was created at 10:20. This resembles an MFA-prompt manipulation or "push fatigue" scenario. It remains an interpretation, not a confirmed attribution.

**Alternative explanation:** The sign-in may have been initiated by student07 or a legitimate service/device using a different network, while the earlier failures were caused by mistyped credentials or a retry. The user's account of approving a prompt makes this less reassuring, but does not identify the operator.

**Two useful checks:** (1) Review identity-provider details for the session and MFA event—device/browser, session identifier, MFA method, registered device and any available risk/context fields—and compare them with student07's known devices. (2) Ask the user and correlate endpoint/network records or other relevant activity around 10:14–10:20, including whether the device was in use and whether the session performed actions. These checks may distinguish scenarios but should be interpreted cautiously.

> The IP address 198.51.100.23 is a reserved documentation example in this exercise. A different IP alone does not prove an attacker or identify a person.

## C3. Three prioritised actions for the authorised IT team

1. **Protect the account:** Contact student07 through a verified channel, reset the password using the approved process, revoke active sessions/tokens, review recovery details and MFA registrations, and require fresh authentication. Do not ask the user to disclose their password or OTP.

2. **Preserve evidence:** Export and securely retain the relevant authentication, MFA and session logs, timestamps, session identifiers and related records before routine retention or deletion. Record who collected them and when, restrict access, and preserve originals so the investigation remains auditable.

3. **Investigate and monitor:** Review the session's device/context and subsequent account activity, check for account changes or suspicious actions, and monitor for further attempts. Escalate according to the institution's incident process and communicate safe next steps to the student.

## C4. Incident summary (78 words)

> On 18 October 2026, student07 had a successful password and MFA sign-in from the usual classroom egress at 09:00–09:01. At 10:14–10:16, two password failures and then a success occurred from a different documentation IP; MFA was denied at 10:17, approved at 10:18, and a session was created at 10:20. The student says they approved a prompt but did not initiate a sign-in. Unauthorised access is plausible, not proven. IT should secure the account, preserve logs and investigate session details.

# Task D — Review an AI security answer

## D1. Five unsafe or unsupported claims/actions and corrections

| AI output claim/action | Correction and reasoning |
|---|---|
| "The email is safe because it uses HTTPS." | Incorrect. HTTPS protects data in transit but does not prove the site or message is genuine. The message requests a password and OTP, creates urgency, has a mismatched Reply-To and discourages contacting the college. Verify through an independently obtained official portal or contact. |
| "The sign-in logs prove that the person using 198.51.100.23 stole the password." | Unsupported. The logs show two failures followed by a password success, MFA denial and approval, and session creation. They do not identify a person or prove how the password was obtained. The IP is a documentation example; investigate device/session evidence. |
| "MFA prevents every account compromise." | False absolute claim. MFA adds a layer of protection, but prompt manipulation, phishing, compromised devices or recovery processes can still lead to compromise. Users should deny unexpected prompts and report repeated requests; stronger phishing-resistant methods are preferable where supported. |
| "Delete the suspicious logs." | Unsafe. Logs are important evidence for determining what happened, scope and timeline. Preserve relevant records securely, restrict access and maintain collection details; do not delete or alter evidence during an investigation. |
| "Send the student's password to support so they can test it." | Unsafe and unnecessary. Support staff should never request or receive the user's password or OTP. Use approved password-reset and account-recovery processes, revoke sessions and verify account security without collecting secrets. |

## D2. Improved prompt for an AI tool

> You are assisting with a cybersecurity training exercise. Analyse only the fictional email evidence and synthetic sign-in events provided below. Do not browse, visit any supplied address, infer a real person's identity or assume facts that are not in the evidence. For each conclusion, separate (a) directly observed facts, (b) reasonable interpretations and (c) unknowns. Identify phishing indicators and explain safe independent verification. Build a timestamped sign-in timeline and provide plausible explanations without treating an IP address as personal attribution. Recommend prioritised account-protection and evidence-preservation actions. Never request, reveal or include passwords, OTPs, identity documents or other secrets. State uncertainty and list what additional evidence would help distinguish explanations. If evidence is insufficient, say so clearly.

## D3. Corrected security advice (124 words)

> Do not use the scholarship message's link or reply to it. It asks for a college password, an OTP and an identity-card photo, applies an artificial deadline, and discourages independent contact. Verify the scholarship by opening the college portal from a trusted bookmark or by contacting the college using details from an official source. HTTPS and a familiar sender name do not prove legitimacy. The sign-in records show a password success, an MFA denial, a later approval and a session creation from a different documentation IP; they do not identify a person or prove password theft. Deny unexpected MFA prompts. If credentials were entered, change reused passwords from a trusted device, revoke sessions, report the event and review account activity. IT should preserve logs and investigate before drawing conclusions.

## D4. AI-use declaration and evidence/reference notes

**AI-use declaration:** ChatGPT (GPT-6) was used to help organise the report, explain cybersecurity concepts and draft wording based on the fictional scenarios in the supplied assessment brief. The output should be reviewed and edited by the student to ensure it reflects their own understanding. No real passwords, OTPs, identity documents or personal account data were provided.

**Evidence note 1 — Assessment brief:** The Task B message evidence and Task C synthetic log table and user statement are the primary evidence used for the phishing and sign-in analysis. Conclusions are limited to those supplied facts; no live website or system was tested.

**Evidence note 2 — Reference guidance:** CISA's Secure Our World guidance is listed in the assessment for basic account-security and phishing awareness. NIST AI 600-1, Generative AI Profile, is listed for understanding

generative-AI limitations such as confabulation and the need to verify outputs. These references support the general approach; the scenario-specific findings come from the assessment evidence.

## References


1. EWB Courses, *AI-Powered Cybersecurity — Assessment 01: Security Foundations*, issued 18 October 2026, pages 1–4 (course-provided assessment brief).

2. Cybersecurity and Infrastructure Security Agency (CISA), *Secure Our World*. https://www.cisa.gov/secure-our-world

3. National Institute of Standards and Technology (NIST), *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, NIST AI 600-1. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf


**Before submission:** Fill in your batch/group, read the report carefully, revise any wording you cannot explain in your own words, and save the final PDF using the filename requested by EWB. The submission deadline will be announced separately; keep the report until the official Google Form is shared.